

W12D1 - Report per Dirigente

Vulnerability Assessment con Nessus su Metasploitable

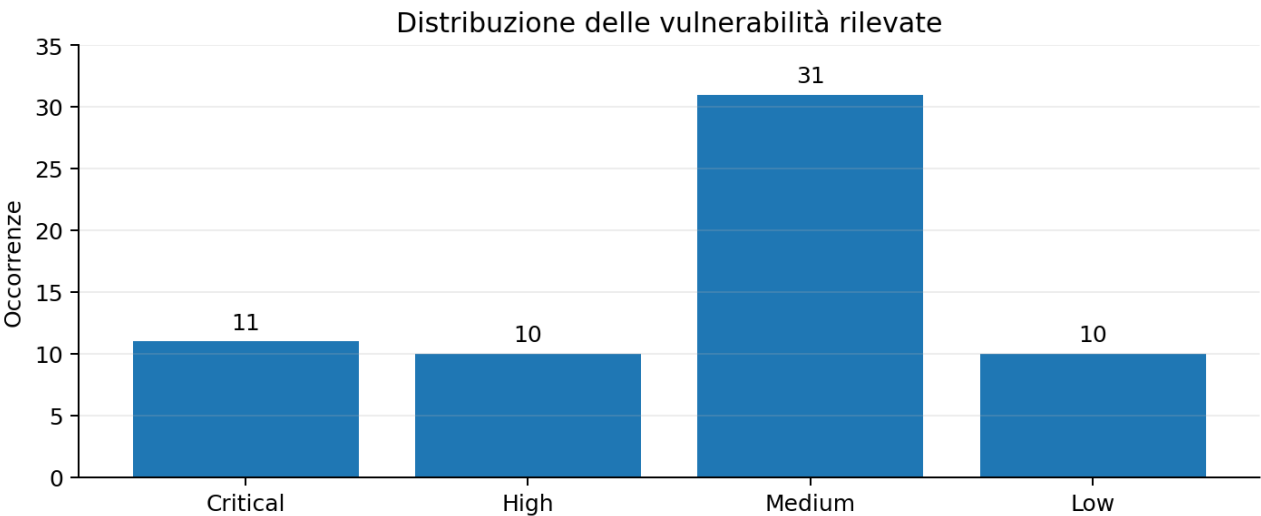
Studente: Riccardo Luzzi
Corso: Cyber Security
Target analizzato: Metasploitable - 192.168.51.101

Sintesi esecutiva

La scansione Nessus ha evidenziato una superficie di attacco elevata, coerente con la natura volutamente vulnerabile di Metasploitable. La scheda Vulnerabilities contiene 86 finding raggruppati. Nella vista del singolo host Nessus riporta 11 occorrenze Critical, 10 High, 31 Medium, 10 Low e 146 Informational. Per il presente riepilogo sono stati considerati soprattutto i problemi Critical e High con maggiore impatto operativo.

Finding raggruppati	Critical	High	Durata scansione
86	11	10	17 min

Grafico 1 - Occorrenze per severità (escluse le 146 informative)



Il dato più rilevante per una valutazione gestionale è la presenza contemporanea di vulnerabilità Critical e High, alcune delle quali consentono accesso remoto o espongono servizi legacy non più adeguati a un ambiente reale.

Principali rischi emersi

Di seguito sono riportati i finding più significativi emersi dall'analisi tecnica, sintetizzati in termini di impatto e azione raccomandata.

Area / finding	Severità	Impatto principale	Intervento raccomandato
Bind shell su 1524/TCP	Critical	Accesso remoto senza autenticazione con privilegi root.	Rimuovere il servizio; trattare il sistema come compromesso e valutare reinstallazione.
VNC con password debole	Critical	Possibile accesso remoto non autorizzato all'interfaccia grafica.	Cambiare la password, limitare l'accesso di rete e disabilitare VNC se inutile.
Ubuntu 8.04 End of Life	Critical	Sistema non più supportato e privo di aggiornamenti di sicurezza.	Migrare servizi e applicazioni verso una versione supportata.
Apache Tomcat AJP Ghostcat	Critical	Lettura di file interni; in alcune configurazioni possibile esecuzione di codice.	Aggiornare Tomcat, limitare/proteggere AJP o disabilitarlo.
SSL/TLS e cifrari obsoleti	Critical	Comunicazioni esposte a protocolli e algoritmi crittografici non più sicuri.	Disabilitare SSLv2/SSLv3/TLS 1.0 e rimuovere cipher obsolete.
Debian/OpenSSL RNG weakness	Critical	Materiale crittografico potenzialmente prevedibile.	Aggiornare OpenSSL/OpenSSH e rigenerare chiavi e certificati.
Samba legacy / Badlock	High	Servizio SMB datato, SMBv1 attivo e accesso anonimo alle share.	Aggiornare Samba, disabilitare SMBv1 e limitare condivisioni e accessi.
rlogin / rsh	High	Servizi legacy non cifrati e basati su meccanismi di trust deboli.	Disabilitare i servizi e utilizzare SSH.
NFS world readable	High	Esportazione della root senza restrizioni specifiche sugli host.	Limitare /etc/exports a host/subnet autorizzati e applicare minimo privilegio.

Valutazione complessiva

I risultati mostrano che il rischio non deriva da un singolo componente, ma dalla combinazione di sistema operativo obsoleto, servizi legacy, configurazioni permissive e vulnerabilità che consentono accesso remoto. In un contesto produttivo la priorità sarebbe ridurre immediatamente l'esposizione dei servizi più critici e pianificare la sostituzione dei componenti non più supportati.

Piano di intervento proposto

Per una gestione efficace del rischio, gli interventi possono essere organizzati in tre fasi operative.

1. Intervento immediato	Rimuovere o isolare la bind shell; cambiare la password VNC; limitare da firewall l'accesso ai servizi esposti; restringere l'export NFS.
2. Messa in sicurezza	Aggiornare Tomcat, Samba, OpenSSL/OpenSSH; disabilitare rlogin, rsh, SMBv1 e protocolli SSL/TLS obsoleti; rigenerare chiavi e certificati vulnerabili.
3. Riduzione strutturale del rischio	Migrare da Ubuntu 8.04 verso un sistema operativo supportato, mantenere inventario e patching regolare e ripetere la scansione Nessus dopo gli interventi per verificarne l'efficacia.

Conclusione

Il Vulnerability Assessment ha individuato criticità che, in un sistema reale, richiederebbero interventi sia immediati sia strutturali. La presenza di una shell root accessibile senza autenticazione rappresenta il rischio più evidente, ma anche l'obsolescenza del sistema operativo e dei servizi aumenta in modo significativo la probabilità di compromissione. La strategia consigliata è quindi combinare contenimento rapido, aggiornamento dei servizi e migrazione verso una piattaforma supportata, seguiti da una nuova scansione di verifica.

Nota sul perimetro

Il documento sintetizza i risultati ottenuti nel laboratorio W12D1. Le prove sono state eseguite esclusivamente sulle macchine virtuali del laboratorio e il presente report ha finalità didattica e di riepilogo gestionale.